

Flutter CIC



Seguridad y privacidad

Referencia técnica

FLUTTER · DOCUMENTACIÓN VERIFICADA

Arquitectura · instalación · manual funcional · desarrollo · operación

Seguridad y privacidad

Controles confirmados

- `ServerPolicy` exige URL HTTPS bien formada.
- La sesión Odoo usa `flutter_secure_storage`; no se recupera desde preferencias sin cifrar.
- Las credenciales no se registran: `AppLogger` redacta claves sensibles y cargas extensas.
- Sentry es opcional y recibe tipo de error/pila, no el mensaje bruto; PII, capturas y jerarquía visual están desactivadas en código.
- La identificación de administrador procede de `session_info.is_admin`, no del nombre de usuario.
- Los reintentos automáticos de RPC están prohibidos para escrituras.
- Android desactiva tráfico HTTP en claro y backup de aplicación en el manifest.
- La UI usa ACL para visibilidad, pero el servidor Odoo autoriza siempre la operación real.

Matriz de autorización del cliente

Operación	Usuario interno	Usuario portal
Ver	ACL de modelo y, cuando aplica, campo <code>permiso_*_ver</code> del contacto	<code>capabilities[modulo].view</code>
Editar	ACL create/write y, cuando aplica, <code>permiso_*_editar</code>	<code>capabilities[modulo].edit</code>
Enviar comunicación	Edición de comunicaciones	<code>communications.send</code>
Completar formación	ACL/permisos correspondientes	<code>training.complete</code>

No hay una matriz de record rules Odoo en este repositorio Flutter. Debe auditarse en `cicancer` antes de cualquier publicación.

Riesgos que siguen abiertos

- Las operaciones integradas contra Odoo real no se pueden comprobar sin entorno autorizado.
- La política de retención y acceso de Sentry/Firebase no está versionada aquí.
- Los adjuntos internos pueden caer en el directorio de documentos de la app si falla el temporal; los de portal forzados usan temporal.
- La aplicación no certifica conformidad WCAG ni pruebas de lectores de pantalla en dispositivos reales.